

PENTEST REPORT

Reconnaissance and Vulnerability Analysis

Target: 10.129.10.90

Generated: 05/06/2026 11:09 · NmapRAG Engine

5	13	11	1	1
Open Ports	Vulnerabilities	Critical	High	Sessions

Report Contents

1	Executive Summary
2	Confirmed Attack Vectors
3	Ports and Services
4	CVE Vulnerabilities — Full Detail
5	Metasploit Exploitation Results
6	Execution Timing
7	Execution Log

1. Executive Summary

Attack Surface Summary

The attack surface is **HIGH** due to the presence of known vulnerabilities and misconfigurations. Specifically, the vsftpd 2.3.4 service on port 21 is known to have a backdoor vulnerability (CVE-2011-2523), and the Samba service (ports 139 and 445) is running an outdated version (3.0.20-Debian) that may be vulnerable to exploits such as EternalBlue (CVE-2017-0144) if not properly patched. Additionally, anonymous access is allowed for FTP and SMB, and SMB message signing is disabled, increasing the risk of relay attacks.

Detected Services and Versions

- **TCP 21:** vsftpd 2.3.4
 - **TCP 22:** OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
 - **TCP 139:** Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
 - **TCP 445:** Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
 - **TCP 3632:** distccd v1 ((GNU) 4.2.4 (Ubuntu 4.2.4-1ubuntu4))
-

Key Findings

- **Anonymous FTP login allowed** (port 21) — allows unauthenticated file enumeration.
 - **vsftpd 2.3.4** is known to have a backdoor vulnerability (CVE-2011-2523).
 - **Samba service** (ports 139 and 445) is running version 3.0.20-Debian, which is vulnerable to known exploits if not properly patched.
 - **SMB message signing is disabled** — increases risk of relay attacks.
 - **Multiple user accounts** listed in Samba configuration, including 'msfadmin', 'root', and 'postgres', which could be targets for enumeration or exploitation if misconfigured.
 - **SSH allows both password and publickey authentication** — could be a target for brute-force or key-based attacks if not properly secured.
-

Recommended Next Steps

1. Exploit vsftpd 2.3.4 backdoor (CRITICAL):

- Use Metasploit module: `exploit/unix/ftp/vsftpd_234_backdoor`
- Command: `msfconsole -x "use exploit/unix/ftp/vsftpd_234_backdoor; set RHOSTS 10.129.10.90; exploit"`
- CVE ID: [CVE-2011-2523](https://cve.mitre.org/cgi-bin/cvekey.cgi?name=CVE-2011-2523)

2. Check for SMB vulnerabilities (MEDIUM):

- Use Metasploit module: `exploit/multi/samba/usermap_script` (for Samba versions 3.0.20-3.0.25)
- Command: `msfconsole -x "use exploit/multi/samba/usermap_script; set RHOSTS 10.129.10.90; exploit"`
- CVE ID: [CVE-2017-0144](https://cve.mitre.org/cgi-bin/cvekey.cgi?name=CVE-2017-0144)

3. Enumerate Samba users (MEDIUM):

- Use Nmap script: `nmap --script smb-enum-users -p 139,445 10.129.10.90`

4. Verify if anonymous SMB access is allowed (MEDIUM):

- Use Nmap script: `nmap --script smb-anon-enum -p 139,445 10.129.10.90`

5. Check for SSH brute-force or misconfigurations (MEDIUM):

- Use Metasploit module: `auxiliary/scanner/ssh/ssh_enumusers`
- Command: `msfconsole -x "use auxiliary/scanner/ssh/ssh_enumusers; set RHOSTS 10.129.10.90; exploit"`

6. Verify distccd service (Not determined):

- Check for known vulnerabilities in distccd v1.4.2.4 (Ubuntu 4.2.4-1ubuntu4) using CVE databases.
- If vulnerable, use Metasploit module: `exploit/unix/ftp/distcc_exec` (if applicable).

2. Confirmed Attack Vectors

5 known vulnerabilities identified by automatic correlation of detected service versions against the exploit knowledge base. These vectors are **confirmed** by exact service version and do not depend on LLM analysis.

[CRITICAL] vsftpd 2.3.4 Backdoor Vulnerability

CVE-2011-2523

Port: 21 · Service: vsftpd vsftpd 2.3.4

[CRITICAL] Samba SMB Vulnerability

CVE-2004-0600

Port: 445 · Service: samba Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)

[CRITICAL] Samba SMB Vulnerability

CVE-2004-1154

Port: 445 · Service: samba Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)

[CRITICAL] Samba SMB Vulnerability

CVE-2004-0882

Port: 445 · Service: samba Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)

[CRITICAL] Samba SMB Vulnerability

CVE-2007-2446

Port: 445 · Service: samba Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)

3. Ports and Services Detected

5 open port(s) detected on target.

Port	Service	Version	Proto	Notes
21	vsftpd	2.3.4	TCP	■ Sensitive service
22	OpenSSH	4.7p1 Debian 8ubuntu1 (protocol 2.0)	TCP	■ Sensitive service
139	Samba	smbd 3.0.20-Debian (workgroup: WORKGROUP)	TCP	
445	Samba	smbd 3.0.20-Debian (workgroup: WORKGROUP)	TCP	■ Sensitive service
3632	distccd	v1 ((GNU) 4.2.4 (Ubuntu 4.2.4-1ubuntu4))	TCP	■ Sensitive service

4. CVE Vulnerabilities — Full Detail

8 CVE(s) identified across exposed services (5 from NVD · 0 from knowledge base).

Severity	Count	Typical Impact
CRITICAL	6	Remote code execution, full system compromise
HIGH	1	Privilege escalation, unauthorised data access
LOW	1	Limited impact, requires specific conditions

Port 21 — vsftpd 2.3.4

[CRITICAL] CVE-2011-2523

9.8

vsftpd 2.3.4 downloaded between 20110630 and 20110703 contains a backdoor which opens a shell on port 6200/tcp.

Published	2019-11-27
CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Attack Vector	NETWORK
CWE	CWE-78

Exploitation context:

Remotely exploitable — no physical access or local presence required. OS Command Injection: possible OS command execution. Known BACKDOOR: verify with Metasploit. Metasploit: exploit/unix/ftp/vsftpd_234_backdoor [Exploit-DB](#) Difficulty: trivial. vsftpd 2.3.4 backdoor: opens a shell on port 6200/tcp.

References:

[packetstormsecurity.com](#)
[Red Hat](#)
[packetstormsecurity.com](#)
[NVD](#)

Port 22 — OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)

[LOW] CVE-2008-5161**3.7**

Error handling in the SSH protocol in (1) SSH Tectia Client and Server and Connector 4.0 through 4.4.11, 5.0 through 5.2.4, and 5.3 through 5.3.8; Client and Server and ConnectSecure 6.0 through 6.0.4; Server for Linux on IBM System z 6.0.4; Server for IBM z/OS 5.5.1 and earlier, 6.0.0, and 6.0.1; and Client 4.0-J through 4.3.3-J and 4.0-K through 4.3.10-K; and (2) OpenSSH 4.7p1 and possibly other versions, when using a block cipher algorithm in Cipher Block Chaining (CBC) mode, makes it easier for remote attackers to recover certain plaintext data from an arbitrary block of ciphertext in an SSH session via unknown vectors.

Published	2008-11-19
CVSS Vector	CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N
Attack Vector	NETWORK
CWE	CWE-200, CWE-329

Exploitation context:

Remotely exploitable — no physical access or local presence required. Sensitive information disclosure without authorisation.

References:

isc.sans.org
kb.juniper.net
lists.apple.com
NVD

Port 445 — Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)

[CRITICAL] CVE-2004-0600**10.0**

Buffer overflow in the Samba Web Administration Tool (SWAT) in Samba 3.0.2 to 3.0.4 allows remote attackers to execute arbitrary code via an invalid base-64 character during HTTP basic authentication.

Published	2004-07-27
CVSS Vector	AV:N/AC:L/Au:N/C:C/I:C/A:C
Attack Vector	NETWORK
CWE	NVD-CWE-Other

Exploitation context:

Remotely exploitable — no physical access or local presence required.

References:

distro.conectiva.com.br
distro.conectiva.com.br
marc.info
NVD

[CRITICAL] CVE-2004-1154**10.0**

Integer overflow in the Samba daemon (smbd) in Samba 2.x and 3.0.x through 3.0.9 allows remote authenticated users to cause a denial of service (application crash) and possibly execute arbitrary code via a Samba request with a large number of security descriptors that triggers a heap-based buffer overflow.

Published	2005-01-10
CVSS Vector	AV:N/AC:L/Au:N/C:C/I:C/A:C
Attack Vector	NETWORK
CWE	NVD-CWE-Other

Exploitation context:

Remotely exploitable — no physical access or local presence required. DoS: may disrupt the service.

References:

ftp.sco.com
lists.apple.com
secunia.com
NVD

[CRITICAL] CVE-2004-0882**10.0**

Buffer overflow in the QFILEPATHINFO request handler in Samba 3.0.x through 3.0.7 may allow remote attackers to execute arbitrary code via a TRANSACT2_QFILEPATHINFO request with a small "maximum data bytes" value.

Published	2005-01-27
CVSS Vector	AV:N/AC:L/Au:N/C:C/I:C/A:C
Attack Vector	NETWORK
CWE	NVD-CWE-Other

Exploitation context:

Remotely exploitable — no physical access or local presence required.

References:

ftp.sco.com
patches.sgi.com
distro.conectiva.com.br
NVD

[CRITICAL] CVE-2007-2446**10.0**

Multiple heap-based buffer overflows in the NDR parsing in smbd in Samba 3.0.0 through 3.0.25rc3 allow remote attackers to execute arbitrary code via crafted MS-RPC requests involving (1) DFSEnum (netdfs_io_dfs_EnumInfo_d), (2) RFNPCNEX (smb_io_notify_option_type_data), (3) LsarAddPrivilegesToAccount (lsa_io_privilege_set), (4) NetSetFileSecurity (sec_io_acl), or (5) LsarLookupSids/LsarLookupSids2 (lsa_io_trans_names).

Published	2007-05-14
CVSS Vector	AV:N/AC:L/Au:N/C:C/I:C/A:C
Attack Vector	NETWORK
CWE	CWE-119

Exploitation context:

Remotely exploitable — no physical access or local presence required. Buffer overflow: may allow arbitrary code execution.

References:

docs.info.apple.com
h20000.www2.hp.com
h20000.www2.hp.com
NVD

[CRITICAL] CVE-2007-4572**9.3**

Stack-based buffer overflow in nmbd in Samba 3.0.0 through 3.0.26a, when configured as a Primary or Backup Domain controller, allows remote attackers to have an unknown impact via crafted GETDC mailslot requests, related to handling of GETDC logon server requests.

Published	2007-11-16
CVSS Vector	AV:N/AC:M/Au:N/C:C/I:C/A:C
Attack Vector	NETWORK
CWE	CWE-119

Exploitation context:

Remotely exploitable — no physical access or local presence required. Buffer overflow: may allow arbitrary code execution.

References:

docs.info.apple.com
lists.apple.com
lists.vmware.com
NVD

Port 3632 — distccd v1 ((GNU) 4.2.4 (Ubuntu 4.2.4-1ubuntu4))

[HIGH] CVE-2004-0601**7.5**

distcc before 2.16, when running on 64-bit platforms, does not interpret IP-based access control rules correctly, which could allow remote attackers to bypass intended restrictions.

Published 2004-12-23

CVSS Vector AV:N/AC:L/Au:N/C:P/I:P/A:P

Attack Vector NETWORK

CWE NVD-CWE-Other

Exploitation context:

Remotely exploitable — no physical access or local presence required.

References:

distcc.samba.org

secunia.com

securityfocus.com

NVD

5. Metasploit Exploitation Results

5 module(s) executed · 2 vulnerable · 1 session(s) opened · 0 error(s)

Execution Plan

#	CVE	CVSS	Module	Result
1	CVE-2007-2447	10.0	exploit/multi/samba/usermap_script	SESSION
2	CVE-2007-2446	10.0	exploit/linux/samba/lsa_transnames_heap	NO RESULT
3	CVE-2011-2523	9.8	exploit/unix/ftp/vsftpd_234_backdoor	VULNERABLE

SESSION OPENED

6. Execution Timing

Total scan duration: **25m 29s** (1529.1s)

Phase	Duration	% of Total
Model warm-up	17s	1.2%
Phase 0 — TCP Discovery	2m 08s	8.4%
Phase 1 — Version Detection	1m 27s	5.7%
Phase 2 — Adaptive NSE	3m 46s	14.8%
Phase 3 — Firewall Detection	10s	0.7%
Phase 4 — UDP Scan	18s	1.2%
Phase 5 — Web Fuzzing	0s	0.0%
Phase 6 — Metasploit	7m 31s	29.5%
Phase 7 — Searchsploit + Creds	6m 38s	26.1%
Total	25m 29s	100%

7. Execution Log

11 step(s) executed during reconnaissance.

✓ Step 1 — Full TCP SYN scan (all 65535 ports)

```
nmap -Pn -sS -p- --min-rate 1000 --max-retries 2 10.129.10.90
```

→ Found: 21 (ftp), 22 (ssh), 139 (netbios-ssn), 445 (microsoft-ds), 3632 (distccd)

✓ Step 2 — Version + OS detection on 21,22,139,445,3632

```
nmap -Pn -sV -O --version-intensity 5 -sC --script-timeout 60s -p 21,22,139,445,3632 -oX /home/marina/Desktop/pentestM/RAG/outputs/nmap_sV_10_129_10_90.xml 10.129.10.90
```

→ Found: 21 (vsftpd 2.3.4), 22 (OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)), 139 (Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)), 445 (Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)), 3632 (distccd v1 ((GNU) 4.2.4 (Ubuntu 4.2.4-1ubuntu4)))

→ Anonymous FTP login allowed (FTP code 230)

→ Samba service running with message signing disabled (dangerous, but default)

→ Multiple OS guesses with high confidence (Linux 2.6.23, Belkin N300 WAP, etc.)

→ Anonymous FTP login allowed (port 21)

→ SMB version detail: 445/tcp open netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)

✓ Step 3 — Check for vsftpd backdoor and anonymous access

```
nmap -Pn -sV --script ftp-vsftpd-backdoor,ftp-anon -p 21 10.129.10.90 --script-timeout 30s
```

→ Found: 21 (vsftpd 2.3.4)

→ Anonymous FTP login allowed (FTP code 230)

→ Anonymous FTP login allowed (port 21)

✓ Step 4 — Check SSH authentication methods

```
nmap -Pn -sV --script ssh-auth-methods -p 22 10.129.10.90 --script-timeout 30s
```

→ Found: 22 (OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0))

→ SSH allows both password and publickey authentication methods

✓ Step 5 — Check Samba for vulnerabilities and misconfigurations

```
nmap -Pn -sV --script smb-vuln-ms17-010,smb-enum-users -p 139 10.129.10.90
--script-timeout 30s
```

→ **Found:** 139 (Samba smbd 3.X - 4.X (workgroup: WORKGROUP))

→ Samba service is running (port 139) with version 3.X - 4.X, which may be vulnerable to known exploits if not properly patched.

→ Multiple user accounts listed in the Samba configuration, including 'msfadmin', 'root', and 'postgres', which could be targets for enumeration or exploitation if misconfigured.

✓ Step 6 — Check Samba for vulnerabilities and misconfigurations

```
nmap -Pn -sV --script smb-vuln-ms17-010,smb-enum-users -p 445 10.129.10.90
--script-timeout 30s
```

→ **Found:** 445 (Samba smbd 3.X - 4.X (workgroup: WORKGROUP))

→ Samba service is running (port 445) with version 3.X - 4.X, which may be vulnerable to known exploits if not properly patched.

→ Multiple user accounts listed in the Samba configuration, including 'msfadmin', 'root', and 'postgres', which could indicate potential misconfigurations or security risks if not properly secured.

✓ Step 7 — ACK scan — firewall detection

```
nmap -Pn -sA -p 21,22,139,445,3632 10.129.10.90
```

✓ Step 8 — UDP scan — top 100 ports by frequency

```
nmap -Pn -sU --top-ports 100 --open --max-retries 1 10.129.10.90
```

✓ Step 9 — UDP scan — exploit-focused service ports

```
nmap -Pn -sU -p 53,67,69,111,123,137,138,161,162,500,623,1434,1900,4500,5353,11211,17185
--open --max-retries 1 10.129.10.90
```

✓ Step 10 — MSF exploitation phase

```
msfconsole (multiple modules)
```

✓ Step 10 — Searchsploit + credential phase

```
searchsploit / paramiko / ftplib
```